

Actividad 10

Traversal sequences stripped with superfluous URL-decode

Bypass de filtro — doble URL-decode

Nombre: Tristán Rivera Magdalena Yesenia

Matrícula: 174702

Materia / Grupo: CNO IV — Programación WAP · T37A

Profesor: Servando López Contreras

Herramienta: Burp Suite Community Edition

URL: <https://portswigger.net/web-security/file-path-traversal/lab-superfluous-url-decode>

OBJETIVO

Evadir el filtro aprovechando que el servidor decodifica la URL dos veces en distintas capas de procesamiento.

EXPLICACIÓN TÉCNICA DE LA VULNERABILIDAD

El filtro revisa el input después de un primer URL-decode y no encuentra `../` literal, así que lo deja pasar. Pero el componente que finalmente abre el archivo hace un **segundo** decode, revelando la secuencia de traversal que estaba doblemente codificada desde el inicio.

PROCEDIMIENTO PASO A PASO

1. Activar Intercept on en Burp y hacer clic en un producto.
2. Interceptar la request de imagen y mandarla a Repeater.
3. Codificar `../` dos veces: `%2e%2e%2f` → `%252e%252e%252f`.
4. Repetir tres veces y añadir `etc/passwd` al final.
5. Enviar y confirmar la fuga de datos en el Response y el badge "Lab solved".

PAYLOAD UTILIZADO

```
GET /image?filename=%252e%252e%252f%252e%252e%252f%252e%252e%252fetc/passwd HTTP/2
```

`%25` es el código URL de `%`. Al decodificar una vez, `%252e` se vuelve `%2e` (todavía codificado, así que el filtro no ve `../`). El segundo decode, hecho por el módulo de archivos, sí lo convierte en `../` real.

MITIGACIÓN RECOMENDADA

Decodificar la URL una única vez, en un solo punto centralizado del pipeline, antes de cualquier validación — y validar después de esa decodificación, nunca antes.

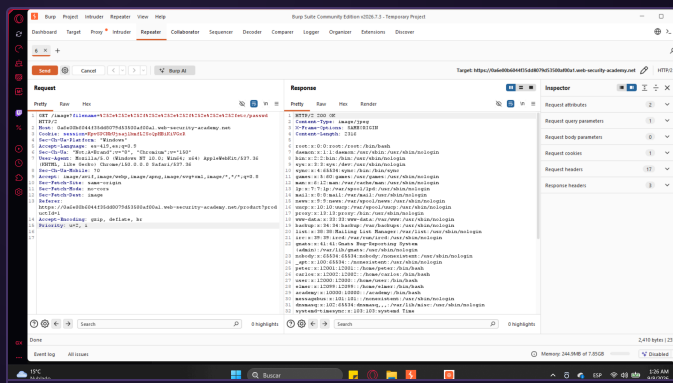


Figura 1. Request en Burp Repeater con el payload + Response con /etc/passwd

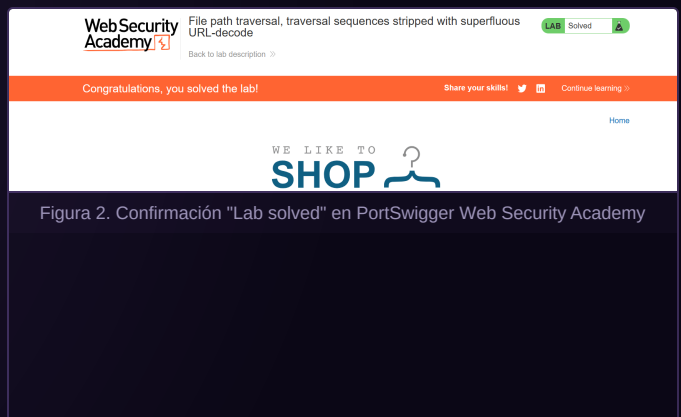


Figura 2. Confirmación "Lab solved" en PortSwigger Web Security Academy